Justin Hosea

Modbus Detection Lab Gap Analysis

Summary

In this gap analysis, I assessed my Modbus detection lab against NIST SP 800-82, using CISA's CSET tool, and ISA/IEC 62443. The detection lab had a total compliance score of 2% when compared to NIST SP 800-82. When scrutinized against ISA/IEC 62443, only 1 requirement was partially met, while the other 6 failed. It also falls short of my SL2 target security level. Additionally, I paralleled my detection lab to Emerson DeltaV assets. The main risks in the lab are unauthorized commands, no segmentation, and no incident recovery or response plans. One thing that is working, however, is that Security Onion detects these unauthorized commands. To solve these issues, I recommend an industrial firewall, then creating a contingency plan and implementing application whitelisting, followed by a SIEM and threat monitoring solution. The main limitation of this lab is that it is a small exercise lab, rather than a real plant environment, so these results describe this lab only.

Scope

This gap analysis is an extension of my previous project (https://github.com/cjhosea/modbus-detection-lab). The previous project showed how an attacker can write malicious Modbus commands to a field controller and this gap analysis is to observe how well that project measures up to OT security standards. The scope of my Modbus Detection Lab is very limited because it is simply a Raspberry Pi and a desktop PC with multiple VMs. There are no HMIs, historians, or other OT assets you would find in a typical industrial environment.

NIST SP 800-82 Rev. 3 is a document that provides guidance on how to secure operational technology assets and the systems and networks surrounding them. Additionally, I used ISA/IEC 62443 alongside NIST SP 800-82. ISA/IEC 62443 is another series of standards that also assists in securing industrial automation and control systems. NIST SP 800-82 offers a broader set of best practices and guidelines, while ISA/IEC 62443 is more prescriptive and specific. Furthermore, NIST SP 800-82 is completely free, while ISA/IEC 62443 requires a payment to be read. With that said, the knowledge I have gained about ISA/IEC 62443 was through a Udemy course and will be focused on 62443 security levels and foundational requirements.

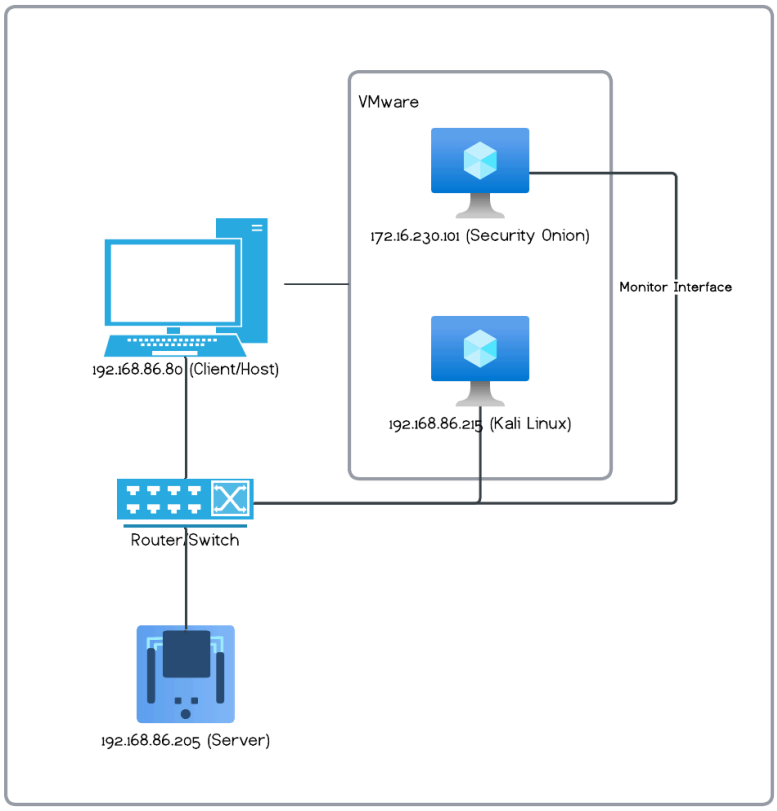
CISA's Cyber Security Evaluation Tool (CSET) is a tool designed to help organizations systematically evaluate their security posture and perform a gap analysis. Using CSET, organizations can assess their ICS networks and systems based on NIST SP 800-82. CSET additionally lets you select an overall security categorization based on NIST SP 800-60 / FIPS 199, where I selected ‘Key Asset & Critical Infrastructure Protection’ to mirror an oil and gas industrial environment. This gave my lab an overall level of ‘High’, so it was judged against the strictest baseline. Lastly, while CSET has built-in assessments against NIST SP 800-82, my mappings to ISA/IEC 62443 were done by hand. I answered the assessment questions based on my knowledge of the lab and my write-up.

System Description

Asset Inventory

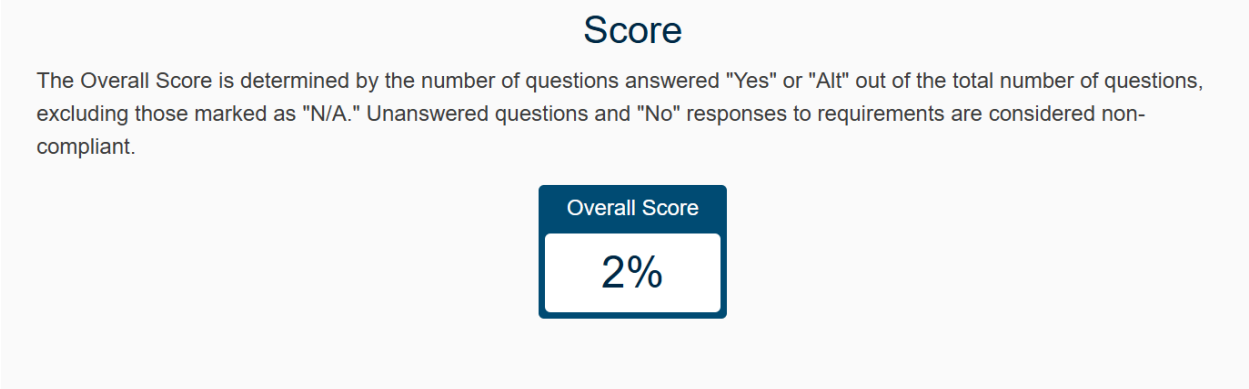
Asset	Role	DeltaV Equivalent	IP	OS	Protocols/Ports	Purdue Level	Zone
Raspberry Pi	Server	DeltaV 200-series PLC	192.168.86.205	Raspberry Pi OS Lite	Modbus/5020	1	Process Control
Desktop	Client/Host	DeltaV SaaS SCADA	192.168.86.80	Arch Linux	TCP Client/Ephemeral	2	Process Control
Security Onion	Network Monitor	DeltaV Network Security Monitor	172.16.230.101	Security Onion	HTTPS/443	2	Process Control

The asset register consists of a short list of assets. To start, there was a Raspberry Pi that represents a Modbus server, or PLC. My desktop PC was the Modbus client, while my Security Onion VM was the network monitor and my Kali Linux VM represented the attacker. Both VMs run on top of my desktop client. Additionally, Modbus was used on port 5020 instead of 502 because 502 is a privileged port. Security Onion uses 172.16.230.101 as its management IP while its monitor interface sniffs network traffic. Kali Linux is not shown in the asset register because it represents an attacker not previously known of in our network.



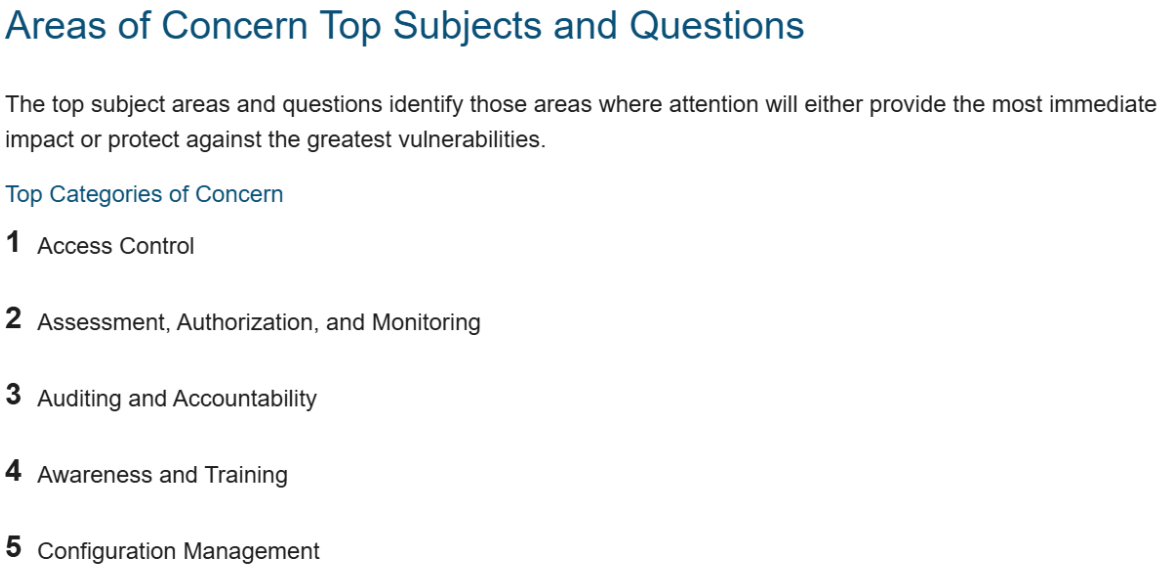
To make this lab more realistic, I mirrored 3 of these 4 components shown in my network diagram to Emerson DeltaV assets. The Raspberry Pi can be a DeltaV 200-series PLC and the client/host can be a DeltaV SaaS SCADA server. Also, the Security Onion VM can represent a DeltaV Network Security Monitor. The DeltaV 200-series PLCs support Modbus TCP and the DeltaV SaaS SCADA systems are aimed at oil and gas corporations. One problem is that because the DeltaV SaaS SCADA server is a cloud solution, it might not be best represented at level 2 of the Purdue Model. It is an approximation. The mapping to DeltaV components is important because it can show how real equipment can be tampered with.

Findings



After completing the CSET site assessment, the Modbus Detection Lab has a compliance score of 2%. Looking at the site summary provided by CSET, it ranked 163 standard requirements the lab didn't meet by importance. Going through all 163 would be a strenuous effort so instead I focused on their rankings by category that are given in the executive summary. The most important category was 'Access Control'. Following 'Access Control' was 'Assessment, Authorization, and Monitoring', 'Auditing and Accountability', 'Awareness and Training', and 'Configuration Management', in that order. What this tells me is that based on CSET's findings, access control should be focused on first, but this should be scrutinized more

carefully as every environment is different. That said, access control is still most likely our top priority because, without proper access control, anyone can access anything. Furthermore, since Modbus has no built-in authentication, proper access control would be of even more use to our environment. To be more specific, some of the NIST SP 800-82 standard requirements the lab fails are the following: Access Enforcement, Least Functionality, Device Identification and Authentication, and Malicious Code Protection.



Areas of Concern Top Subjects and Questions

The top subject areas and questions identify those areas where attention will either provide the most immediate impact or protect against the greatest vulnerabilities.

Top Categories of Concern

1 Access Control

2 Assessment, Authorization, and Monitoring

3 Auditing and Accountability

4 Awareness and Training

5 Configuration Management

Comparing this against ISA/IEC 62443, in the context of using DeltaV assets, I determined that our target security level (SL-T) should be SL2 at the minimum, which is ‘protection against intentional misuse by simple means’. However, at our current achieved security level (SL-A), we are under SL2. To solve this inadequacy, we can, for example, add compensating controls, such as firewalls. Moving along to 62443’s 7 foundational requirements, I compared my lab against each. The first is FR1: Identification and Authentication Control. The Modbus Detection Lab fails this requirement as I was able to freely connect to my Modbus server with my client PC without any identification or authentication. Second is FR2: Use

Control. This requirement is to enforce assigned privileges to authenticated users only. To put it shortly, this is the principle of least privilege. The lab also fails this as there is no authentication in the first place to implement the principle of least privilege. Third is FR3: System Integrity. This requirement is to ensure integrity to prevent unauthorized manipulation. The lab fails this requirement as I was able to use Kali Linux, as an attacker, to modify coils and registers. FR4 is Data Confidentiality. The Modbus Detection Lab fails this requirement because, as the attacker, I was able to freely read the registers and coils of the Modbus server. FR5 is Restricted Data Flow. This requirement is to segment control systems via zones and conduits. In theory, this lab has zones and conduits, which are shown in my previous lab's Github, but they are not enforced so this requirement also fails. FR6 is Timely Response to Events, which is to respond to security violations promptly with timely reporting and decision making. Using Security Onion, this requirement is partially met and alerts us to security violations, but since the attacker was able to freely modify and read registers and coils from our server with no incident response plan from the blue team, it also partly fails. Lastly, FR7 is resource availability, which is ensuring system and asset availability, even during DoS. This last requirement was not tested, but we can also assume that this requirement would fail since we have no backups or contingency plans. Therefore, out of the 7 requirements assessed, I have determined that 6 of them fail and 1 was partially met.

Remediation Plan

Because the lab mirrors Emerson's DeltaV assets, I note Emerson products where they fit. I am going to list some failed NIST SP 800-82 standard requirements and their failed 62443 corresponding foundational requirements, where applicable, and some solutions for them. To

start off, CM-7 (5): ‘Least Functionality | Authorized Software’ states that the DHS recommends using application allowlisting for OT equipment. For example, Emerson’s application whitelisting will allow us to achieve this. I would also do some system hardening and disable unnecessary ports and services. Next, SI-4: ‘System Monitoring’ is to ensure the use of monitoring tools and techniques does not adversely impact the operational performance of the OT. PL-9: ‘Central Management’ is to consider centrally managing flaw remediation, malicious code protection, logging, and incident response. Using a SIEM and threat monitoring solution, like those provided by Emerson for DeltaV, would not only help us fulfill both these aforementioned requirements, but help us fulfill FR6 more adequately. The only thing we would need to do, in addition, is build a robust incident response plan. AC-4: ‘Information Flow Enforcement’ says that information flow policy may be achieved using a combination of logical and physical flow restriction techniques. This access control requirement can be solved using an OT-aware firewall, such as the Emerson NGFW. It would also help fulfill FR5 as it would be a conduit to help segment our zones. In addition to that, this NGFW is Modbus-aware, which could help us fulfill FR2 and FR3 as well. We can also use OPC UA instead of Modbus to enforce security policies where supported or use Modbus TCP Security that has TLS built-in. They both add authentication, which helps fulfill FR1 and TLS is encrypted, which helps fulfill FR4. Lastly, CP-2: ‘Contingency Plan’ states we should define contingency plans for categories of disruptions or failures. Alongside, using SANS’s OT Disaster Recovery guide to create a Disaster Recovery Plan, we can use Emerson’s backup and recovery solutions, which helps us fulfill both CP-2 and FR7.

To prioritize these remediations, I would start with implementing the NGFW for access control purposes. Following that, I would work on the contingency plan because a disaster could

happen at any moment. Next, I would implement application whitelisting to try to ensure least functionality. Lastly, ‘Central Management’ has the least immediate concern and Security Onion already helps cover it partially, so I would focus on that last.

Citations

https://github.com/cjhosea/gap-analysis-mb/blob/main/docs/Executive%20Summary%20-%20Modbus%20Detection%20Lab.pdf

https://github.com/cjhosea/gap-analysis-mb/blob/main/docs/Site%20Summary%20-%20Modbus%20Detection%20Lab.pdf

https://www.cisa.gov/resources-tools/services/cyber-security-evaluation-tool-csetr

https://www.cisa.gov/resources-tools/resources/cyber-security-evaluation-tool-cset-fact-sheet-public-safety

https://csrc.nist.gov/pubs/sp/800/82/r3/final

https://www.udemy.com/course/the-complete-industrial-cybersecurity-guide-for-ot-ics/

https://www.sans.org/posters/ot-disaster-recovery-quick-start-guide

https://www.modbus.org/modbus-specifications

https://www.emerson.com/en/automation-systems/deltav/cybersecurity

https://www.emerson.com/en/automation-systems/deltav